

MATRIZ DE CONTROL DE ACCESO

Matriz de Control de Acceso IAM

Plataforma de datos en streaming - Kinesis, Glue y S3

Autora	Daiana Aranda	Entorno	dev - cuenta 111122223333
Servicios	Kinesis Data Streams, AWS Glue, Amazon S3, AWS KMS	Región	us-east-1
Principios	Mínimo privilegio, separación de responsabilidades, blast radius acotado	Versión	1.0

1. Introducción

Este documento define el modelo de permisos de una plataforma de ingesta en tiempo real que recibe eventos en **Kinesis Data Streams**, los persiste en la capa RAW de un Data Lake en **Amazon S3** y los cataloga en **AWS Glue**. Tanto el stream como los objetos están cifrados con una clave gestionada por el cliente (CMK) de **AWS KMS**.

El diseño parte de una premisa: los tres actores que operan la plataforma tienen necesidades disjuntas, y confundirlas es la principal fuente de exposición. El pipeline de despliegue **crea** los recursos pero no debe leer los datos que contienen; el proceso de ingesta **mueve** datos pero no debe alterar la infraestructura; el ingeniero **observa** pero no modifica nada. Cada rol recibe únicamente las acciones necesarias para su función, acotadas a ARNs explícitos.

Los permisos descritos corresponden al entorno de desarrollo. Producción replica la estructura en una cuenta de AWS distinta (444455556666), con sus propios recursos, su propia CMK y sus propios roles: no existe ningún principal con acceso simultaneo a ambos entornos.

1.1 Convenciones de nomenclatura

Para mantener las tablas legibles, los ARNs completos se abrevian con las referencias siguientes. Ninguna política de este documento usa comodines en el campo Resource para acciones de escritura.

Referencia	ARN completo	Descripción
\${STREAM}	arn:aws:kinesis:us-east-1:111122223333:stream/ingesta-streaming-dev	Stream que recibe los eventos
{BUCKET}	arn:aws:s3:::datalake-raw-dev-111122223333	Bucket de la capa RAW del Data Lake
{KMS}	arn:aws:kms:us-east-1:111122223333:key/a1b2c3d4 (alias/datalake-dev)	CMK que cifra el stream y los objetos
{GLUE_DB}	arn:aws:glue:us-east-1:111122223333:database/datalake_dev	Base de datos del catalogo
{GLUE_TBL}	arn:aws:glue:us-east-1:111122223333:table/datalake_dev/raw_eventos	Tabla catalogada de la capa RAW
{LOG_GRP}	arn:aws:logs:us-east-1:111122223333:log-group:/aws/lambda/ingesta-kinesis-s3-dev:*	Grupo de logs del proceso de ingesta
{TFSTATE}	arn:aws:s3:::tfstate-dev	Bucket del state de Terraform, distinto del de datos
{LOCK_TBL}	arn:aws:dynamodb:us-east-1:111122223333:table/locks-dev	Tabla de locking del state

2. Separación Control Plane / Data Plane

La distinción que estructura toda la matriz separa las operaciones que actúan **sobre el contenedor** de las que actúan **sobre el contenido**. Son planos distintos de la API de AWS y deben estar en manos distintas.

Dimensión	Control Plane	Data Plane
Qué manipula	El recurso como objeto de infraestructura: existencia, capacidad, cifrado, políticas	Los registros y archivos que viven dentro del recurso

Dimensión	Control Plane	Data Plane
Ejemplos	kinesis:CreateStream s3:CreateBucket glue:CreateTable iam:PutRolePolicy	kinesis:GetRecords s3:PutObject glue:StartJobRun kms:GenerateDataKey
Quien lo ejerce	Rol de Despliegue (Terraform / CI-CD)	Rol de Ejecución (servicio de ingesta)
Frecuencia	Baja: solo durante despliegues	Alta: continua, por cada evento procesado
Auditoría	CloudTrail management events, activos por defecto	CloudTrail data events, requieren habilitación explícita

2.1 Matriz resumen de responsabilidades

Rol	Control Plane	Data Plane	Alcance	Credencial
Despliegue (CI/CD)	SI, ciclo de vida completo	NO, salvo su propio state	Cuenta dev	OIDC federado, sin claves de larga vida
Ejecución (servicio)	NO	SI, lectura de stream y escritura en RAW	Stream y prefijo raw/	Credenciales temporales del servicio
Operador (humano)	NO	Solo lectura	Cuenta dev únicamente	AssumeRole con MFA obligatorio

EL ERROR QUE ESTA SEPARACIÓN EVITA

Confundir despliegue con ejecución es el fallo más frecuente. El pipeline necesita crear el bucket, pero no leer los datos que se guardan adentro. Si el rol de CI/CD tuviera s3:GetObject, cualquier compromiso del repositorio o de un runner se convertiría en una fuga del Data Lake completo, sin necesidad de tocar la infraestructura.

3. Rol de Despliegue (Terraform / CI-CD)

Nombre: role-terraform-deploy-dev **Plano:** Control Plane **Uso:** ejecuciones de terraform plan/apply desde el pipeline.

3.1 Trust Policy

El rol se asume por federación OIDC desde GitHub Actions. No existen claves de acceso de larga vida almacenadas en el repositorio: el pipeline obtiene credenciales temporales por ejecución. La condición sobre sub limita el permiso a la rama principal de un repositorio concreto, de modo que un fork o una rama arbitraria no pueden asumirlo.

```
{
  "Version": "2012-10-17",
  "Statement": [{
    "Effect": "Allow",
    "Principal": {
      "Federated": "arn:aws:iam::111122223333:oidc-provider/token.actions.githubusercontent.com"
    },
    "Action": "sts:AssumeRoleWithWebIdentity",
    "Condition": {
      "StringEquals": {
        "token.actions.githubusercontent.com:aud": "sts.amazonaws.com"
      },
      "StringLike": {
        "token.actions.githubusercontent.com:sub":
          "repo:arandadaiana/proyecto_data_engineering:ref:refs/heads/main"
      }
    }
  }]
}
```

3.2 Permisos

Acción de la API	Recurso (ARN)	Justificación de seguridad
kinesis:CreateStream kinesis:DeleteStream kinesis:UpdateShardCount kinesis:StartStreamEncryption kinesis:AddTagsToStream	\${STREAM}	Ciclo de vida del stream. Acotado al ARN del entorno: el rol de dev no alcanza el stream de producción, que vive en otra cuenta.
kinesis:DescribeStream kinesis:DescribeStreamSummary kinesis:ListTagsForStream	\${STREAM}	Lectura de metadatos que Terraform necesita para calcular el plan. Devuelven configuración, nunca registros del stream.
s3:CreateBucket s3:PutBucketVersioning s3:PutEncryptionConfiguration s3:PutBucketPublicAccessBlock s3:PutLifecycleConfiguration	\${BUCKET}	Configuración a nivel bucket, que es control plane puro. Incluye las medidas defensivas del propio bucket: cifrado y bloqueo de acceso público.
s3:GetBucketLocation s3:GetBucketVersioning s3:GetEncryptionConfiguration s3:ListBucket	\${BUCKET}	Lectura de configuración para el refresh del state. ListBucket enumera nombres de objeto, no su contenido.
s3:GetObject s3:PutObject s3:DeleteObject	\${BUCKET}/*	NO SE CONCEDE. Exclusión deliberada y central del diseño: el pipeline crea el contenedor pero nunca accede a los datos. Una credencial de CI comprometida no puede exfiltrar el Data Lake.
s3:GetObject s3:PutObject	\${TFSTATE}/dev/*	Unica excepción de objetos, y sobre un bucket distinto: Terraform lee y escribe su propio state. Acotada al prefijo del entorno.
dynamodb:GetItem dynamodb:PutItem dynamodb:DeleteItem	\${LOCK_TBL}	State locking. Sin DeleteTable ni Scan: solo las tres operaciones que el backend necesita sobre el item de bloqueo.
glue:CreateDatabase glue:CreateTable glue:UpdateTable glue:DeleteTable glue:CreateJob / UpdateJob	\${GLUE_DB} \${GLUE_TBL}	Definición del catalogo y de los jobs como artefactos de infraestructura.
glue:StartJobRun	-	NO SE CONCEDE. Ejecutar un job es data plane. Si el pipeline pudiera lanzarlo, heredaría de hecho los permisos del rol de ejecución y la separación quedaría anulada.
iam:CreateRole / DeleteRole iam:PutRolePolicy iam:AttachRolePolicy iam:GetRole / TagRole	arn:aws:iam::111122223333:role/datalake-*	Crea los roles de servicio del proyecto. Acotado por prefijo de nombre: no puede modificar roles de administración, de auditoría, ni el suyo propio.
iam:PassRole <i>con Condition</i> iam:PassedToService in {lambda, glue}.amazonaws.com	arn:aws:iam::111122223333:role/datalake-ingesta-exec-dev	Vector clásico de escalada de privilegios. Sin la condición, el pipeline podría asignar un rol privilegiado a un recurso que el mismo controla y heredar sus permisos.
kms:CreateKey / CreateAlias kms:PutKeyPolicy kms:DescribeKey kms:ScheduleKeyDeletion	\${KMS}	Ciclo de vida de la clave de cifrado.
kms:Decrypt kms:GenerateDataKey	\${KMS}	NO SE CONCEDE. El rol crea la clave pero no puede usarla. Aunque por un error de política obtuviera un objeto del bucket, seguiría siendo incapaz de descifrarlo: son dos barreras independientes.

DENY EXPLÍCITO COMPLEMENTARIO

La política cierra con un Deny sobre todo ARN de la cuenta 444455556666 y sobre iam:* fuera del prefijo datalake-*. En IAM un Deny explícito prevalece siempre sobre cualquier Allow, incluso sobre uno agregado después por error. Funciona como red de seguridad frente a cambios futuros.

4. Rol de Ejecución del Proceso (Service Role)

Nombre: datalake-ingesta-exec-dev **Plano:** Data Plane **Uso:** lo asume la función Lambda que consume el stream y escribe en la capa RAW.

4.1 Trust Policy

El rol solo puede ser asumido por el servicio Lambda, y únicamente en nombre de la función concreta de este proyecto. Las condiciones `aws:SourceAccount` y `aws:SourceArn` previenen el problema del *confused deputy*: sin ellas, cualquier función Lambda de cualquier cuenta podría inducir al servicio a asumir este rol.

```
{
  "Version": "2012-10-17",
  "Statement": [{
    "Effect": "Allow",
    "Principal": { "Service": "lambda.amazonaws.com" },
    "Action": "sts:AssumeRole",
    "Condition": {
      "StringEquals": { "aws:SourceAccount": "111122223333" },
      "ArnLike": {
        "aws:SourceArn":
          "arn:aws:lambda:us-east-1:111122223333:function:ingesta-kinesis-s3-dev"
      }
    }
  }]
}
```

4.2 Permisos

Acción de la API	Recurso (ARN)	Justificación de seguridad
kinesis:GetRecords kinesis:GetShardIterator kinesis:ListShards kinesis:DescribeStreamSummary	\${STREAM}	Consumo del stream. Es el conjunto mínimo que exige el event source mapping de Lambda.
kinesis:PutRecord kinesis:PutRecords	-	NO SE CONCEDE. Este proceso consume, no produce. Sin permiso de escritura, un defecto o un compromiso no puede contaminar la fuente con registros falsos.
kinesis>DeleteStream kinesis:MergeShards kinesis:SplitShards	-	NO SE CONCEDE. Son control plane. El proceso de datos nunca altera la topología del stream: eso corresponde al pipeline.
s3:PutObject	\${BUCKET}/raw/*	Escritura acotada al prefijo raw/. No puede escribir en capas posteriores (curated/, analytics/), que tienen otros dueños y otros procesos.
s3:AbortMultipartUpload	\${BUCKET}/raw/*	Permiso de soporte que el SDK requiere para cargas multiparte. Sin el, un fallo a mitad de carga deja partes huérfanas que siguen facturando.
s3:ListBucket con Condition s3:prefix = raw/*	\${BUCKET}	ListBucket es un permiso de bucket, no de objeto: sin la condición de prefijo el proceso podría enumerar el bucket completo.
s3>DeleteObject	-	NO SE CONCEDE. La capa RAW es append-only y funciona como fuente de verdad. Sin borrado, ningún defecto del proceso puede destruir el histórico.
s3:GetObject	-	NO SE CONCEDE. El proceso escribe pero no relee. Si el diseño lo requiriera, se acotaría al mismo prefijo raw/.
kms:GenerateDataKey	\${KMS}	Permiso de soporte obligatorio. Con SSE-KMS activo, PutObject falla sin el: S3 necesita solicitar una data key para cifrar cada objeto. Es la omisión más habitual en este tipo de matriz.
kms:Decrypt	\${KMS}	Necesario porque el stream está cifrado con la misma CMK: sin este permiso, GetRecords devuelve los registros ilegibles.
logs:CreateLogStream logs:PutLogEvents	\${LOG_GRP}	Observabilidad del proceso. Se omite CreateLogGroup a propósito: el grupo lo crea Terraform con su retención definida, de modo que el proceso no pueda generar grupos sin política de expiración.
glue:GetTable glue:GetPartitions glue:BatchCreatePartition	\${GLUE_DB} \${GLUE_TBL}	Registrar las particiones nuevas a medida que llegan datos. Sin UpdateTable ni DeleteTable: no puede alterar el esquema, solo agregar particiones.

5. Rol de Operador Humano (Data Engineer)

Nombre: datalake-operador-dev **Plano:** solo lectura **Uso:** monitoreo y depuración en desarrollo. **No existe un rol equivalente en producción:** allí el diagnostico se hace sobre métricas y logs agregados, sin acceso a los datos.

5.1 Trust Policy

Se asume desde la cuenta de identidades, con MFA obligatorio y vigencia acotada. La condición sobre MultiFactorAuthAge exige que el segundo factor se haya presentado dentro de la última hora, de modo que una sesión olvidada no siga habilitando el acceso indefinidamente.

```
{
  "Version": "2012-10-17",
  "Statement": [{
    "Effect": "Allow",
    "Principal": { "AWS": "arn:aws:iam::999988887777:root" },
    "Action": "sts:AssumeRole",
    "Condition": {
      "Bool": { "aws:MultiFactorAuthPresent": "true" },
      "NumericLessThan": { "aws:MultiFactorAuthAge": "3600" }
    }
  }]
}
```

MaxSessionDuration: 3600 segundos

5.2 Permisos

Acción de la API	Recurso (ARN)	Justificación de seguridad
logs:FilterLogEvents logs:GetLogEvents logs:StartQuery logs:GetQueryResults	\${LOG_GRP}	Depuración sobre los logs del proceso de ingesta, acotada al grupo del entorno de desarrollo.
cloudwatch:GetMetricData cloudwatch:ListMetrics cloudwatch:DescribeAlarms	* (ver nota)	CloudWatch no admite permisos a nivel de recurso para estas acciones: la API no expone ARNs de métrica. Se acepta el comodín porque son operaciones de solo lectura sobre datos agregados. El criterio de no usar comodines aplica a acciones de escritura.
kinesis:DescribeStreamSummary kinesis:ListShards	\${STREAM}	Diagnostico de la ingesta: antigüedad del iterador, throttling, número de shards.
kinesis:GetRecords kinesis:GetShardIterator	\${STREAM}	Inspección de registros para depurar formato. Concede acceso a datos reales, y por eso este rol existe únicamente en desarrollo y su uso queda auditado como data event.
s3:ListBucket s3:GetObject	\${BUCKET} \${BUCKET}/raw/*	Verificar los archivos generados por la ingesta. Lectura exclusivamente: ninguna acción de escritura.
kms:Decrypt	\${KMS}	Permiso de soporte: sin el, GetObject sobre objetos cifrados con SSE-KMS falla con AccessDenied aunque el permiso de S3 esté concedido.
glue:GetDatabase / GetTable glue:GetPartitions glue:GetJobRun / GetJobRuns	\${GLUE_DB} \${GLUE_TBL}	Consultar esquema y estado de ejecuciones. Sin StartJobRun: relanzar un job es una operación de cambio y va por el pipeline.
Deny sobre s3:PutObject / DeleteObject kinesis:PutRecord glue:StartJobRun / UpdateTable	*	Deny explícito sobre toda acción de modificación. El operador observa; los cambios se aplican por el pipeline, donde quedan versionados y revisados. Un Deny con comodín restringe , no concede: no contradice el criterio de no usar Resource "*".
Deny sobre toda acción	arn:aws:*:*:444455556666:*	Barrera de entorno. Aunque una política futura concediera permisos amplios, el Deny explícito prevalece y mantiene al operador fuera de producción.

POR QUÉ EL OPERADOR NO PUEDE ESCRIBIR

Un permiso de escritura concedido a una persona rompe la trazabilidad de la infraestructura: el estado real deja de coincidir con el código y Terraform revierte o duplica recursos en el siguiente apply. Restringir al operador a lectura no es desconfianza, es preservar el modelo declarativo.

6. Estrategia de Auditoría

Los permisos definen lo que *puede* ocurrir; la auditoría registra lo que *ocurrió*. Sin trazabilidad, una política mal acotada puede explotarse durante meses sin dejar rastro. Los registros se centralizan en una cuenta de auditoría independiente, a la que ninguno de los tres roles descritos tiene acceso: quien puede actuar no puede borrar la evidencia de su acción.

Servicio	Qué registra	Roles vigilados	Configuración clave
CloudTrail management events	Toda llamada de control plane: CreateStream, CreateBucket, PutRolePolicy, CreateKey	Despliegue Operador	Trail de organización, multi-región, validación de integridad de archivos y destino en cuenta de auditoría con Object Lock
CloudTrail data events	Acceso a datos: s3:GetObject / PutObject y kinesis:GetRecords / PutRecord	Ejecución Operador	No se registran por defecto. Hay que habilitarlos por bucket y por stream. Tienen costo por evento, así que se acotan a \${BUCKET} y \${STREAM}
CloudWatch Logs + Metric Filters	Logs de ejecución del proceso y errores de aplicación	Ejecución	Retención 30 días en dev y 400 en producción. Filtro sobre AccessDenied que dispara alarma
AWS Config	Deriva de configuración respecto del estado declarado	Todos	Reglas s3-bucket-server-side-encryption-enabled, s3-bucket-public-read-prohibited e iam-policy-no-statements-with-admin-access
IAM Access Analyzer	Políticas que conceden acceso externo y permisos concedidos pero nunca usados	Todos	Analizador a nivel organización. Los hallazgos de acceso no usado se revisan cada mes para poder permisos sobrantes
GuardDuty	Uso anómalo de credenciales y patrones de exfiltración	Todos	Habilitado en todas las cuentas; hallazgos de severidad alta enrutados a SNS

6.1 Matriz de trazabilidad por rol

Rol	Evento característico	Dónde queda registrado	Alerta configurada
Despliegue	iam:PutRolePolicy, kms:PutKeyPolicy	CloudTrail management events	Cambio de política IAM fuera de la ventana de despliegue
Despliegue	sts:AssumeRoleWithWebIdentity	CloudTrail + logs de GitHub Actions	Asunción desde un repositorio o rama no autorizados
Ejecución	s3:PutObject, kms:GenerateDataKey	CloudTrail data events	Escritura fuera del prefijo raw/
Ejecución	AccessDenied en cualquier acción	CloudWatch Logs + metric filter	Cualquier ocurrencia: indica permiso faltante o intento fuera de alcance
Operador	s3:GetObject, kinesis:GetRecords	CloudTrail data events	Volumen de lectura inusual, o lectura por un principal distinto del rol de ejecución
Operador	sts:AssumeRole sin MFA	CloudTrail management events	Intento de asunción sin segundo factor

LA OMISIÓN MÁS COSTOSA

Los data events de CloudTrail están desactivados por defecto. Una matriz de permisos impecable sin ellos deja sin registro precisamente lo que más importa: quién leyó qué dato y cuándo. Los management events dirían que el bucket existe, pero no que alguien descargó su contenido.

7. Conclusión

El modelo descansa en tres barreras independientes. La primera es la **separación de planos**: quien crea la infraestructura no accede a los datos, y quien procesa datos no modifica la infraestructura. La segunda es el **acotamiento por ARN**: cada permiso apunta a recursos nombrados, de modo que el alcance de una credencial comprometida queda limitado a un entorno. La tercera es la **independencia de la CMK**: el cifrado actúa como control adicional, y por eso el rol de despliegue puede crear la clave pero no usarla.

El efecto conjunto es que ningún compromiso individual basta para acceder al Data Lake. Un atacante que obtuviera las credenciales del pipeline podría dañar la infraestructura, pero no leer un solo registro; uno que comprometiera el proceso de ingesta podría escribir en el prefijo raw/, pero no borrar el histórico ni alcanzar producción. Esa es la reducción del blast radius que persigue el diseño.